

TSEC Risk & Cyber Advisory

www.tsecgrc.com | Info@tsecgrc.com

EXECUTIVE GUIDE

NIST CSF 2.0 Executive & Practitioner Guide

TSEC Executive Guide Series | Understanding and Applying the NIST Cybersecurity Framework 2.0

Document Version	1.0
Effective Date	September 2026
Classification	PUBLIC
Prepared by	TSEC Risk & Cyber Advisory LLC
Review Cycle	Annual

© 2026 TSEC Risk & Cyber Advisory LLC. All rights reserved. Free to distribute unmodified; not for resale.

TSEC Technical Data Sheet

Every resource published in the TSEC Compliance Library™ includes this standardized technical data sheet, summarizing the resource's identity, scope, and intended use at a glance.

Library	TSEC Executive Guide Series
Framework	NIST Cybersecurity Framework (CSF) 2.0
Publication	Executive & Practitioner Guide
Category	Cybersecurity Risk Management
Resource Name	NIST CSF 2.0 Executive & Practitioner Guide
Document Type	Executive Guide
File Format	PDF / DOCX
Tier	Free Resource
Editable	No
Language	English
Target Audience	CEOs, CISOs, Compliance Leads, GRC Practitioners
Cross-Mapped Frameworks	ISO/IEC 27001, SOC 2 Trust Services Criteria, NIST SP 800-53
Approval Authority	TSEC Risk & Cyber Advisory LLC
Review Frequency	Annual
Owner	TSEC Risk & Cyber Advisory LLC
Version	1.0
Status	Published
License	TSEC Resource Library — free distribution, unmodified

Contents

TSEC Technical Data Sheet	2
Contents	3
About This Guide	4
01. NIST CSF 2.0 at a Glance.....	4
02. What's New in CSF 2.0	4
03. Understanding the CSF Core	5
04. The Govern Function (GV)	5
05. The Identify Function (ID).....	6
06. The Protect Function (PR).....	6
07. The Detect Function (DE).....	6
08. The Respond Function (RS).....	7
09. The Recover Function (RC)	7
10. CSF Tiers — Organizational Risk Management Maturity.....	8
11. CSF Profiles — Current State, Target State, Gaps.....	8
12. Applying CSF 2.0 — A Practical Implementation Path	9
13. Worked Example — Building a Simple Organizational Profile	9
14. CSF 2.0 Quick Reference	10
15. Common Implementation Gaps.....	11
16. TSEC NIST CSF 2.0 Approach	11
17. From Framework to Implementation.....	12
Revision History	12

About This Guide

This guide explains the NIST Cybersecurity Framework (CSF) 2.0 in practical terms for both executives and practitioners — what it is, how the Core is structured, what changed with the addition of the Govern function, and how to move from reading the framework to actually applying it through Profiles and a gap-driven action plan.

This guide is educational and does not replace the authoritative NIST publication. The full CSF 2.0 Core, informative references, and implementation examples are published by NIST at nist.gov/cyberframework.

01. NIST CSF 2.0 at a Glance

The NIST Cybersecurity Framework (CSF) is a voluntary, outcome-based framework for managing and reducing cybersecurity risk. It does not prescribe specific technical controls; instead it describes **what good cybersecurity outcomes look like**, leaving organizations free to choose how to achieve them — which is why it pairs naturally with certifiable standards like ISO/IEC 27001 or attestation frameworks like SOC 2.

Published in February 2024, CSF 2.0 is the first major revision since CSF 1.1 (2018). Two changes define the update: the addition of a sixth function, **Govern**, and an explicit broadening of scope from critical infrastructure to **organizations of any size or sector**.

02. What's New in CSF 2.0

- **Govern (GV) added as a sixth Function** — governance was folded into Identify in CSF 1.1; it is now elevated to a standalone function, reflecting that technical controls alone cannot succeed without strategy, accountability, and oversight.
- **Universal applicability** — CSF 2.0 explicitly targets organizations of every size and sector, not only critical infrastructure operators.
- **Two new Protect categories** — Platform Security (PR.PS) and Technology Infrastructure Resilience (PR.IR) consolidate and modernize categories that were fragmented in 1.1.
- **A new Improvement category (ID.IM)** — consolidates continuous-improvement outcomes that were previously scattered across Respond and Recover.
- **Implementation Examples** — CSF 2.0 adds concrete illustrative actions under many Subcategories, making the framework more actionable for organizations without a mature GRC function.

03. Understanding the CSF Core

The CSF Core is organized as a hierarchy of three levels:

Level	What It Is
Function	The highest level — six Functions organize cybersecurity outcomes into the broad activities of Govern, Identify, Protect, Detect, Respond, and Recover.
Category	Each Function is divided into Categories — groups of related outcomes, such as Asset Management or Incident Analysis. CSF 2.0 defines 22 Categories in total.
Subcategory	Each Category is divided into Subcategories — specific, measurable outcomes. Subcategories are the level at which most assessments and Profiles are built.

Functions are not a sequence — an organization does not “finish” Identify before starting Protect. All six operate continuously and concurrently, informing and reinforcing one another.

04. The Govern Function (GV)

Govern establishes and monitors an organization's cybersecurity risk management strategy, expectations, and policy. It sets direction for the other five Functions and connects security outcomes to business mission and stakeholder needs. Its elevation to a standalone Function in CSF 2.0 reflects a widely observed gap: organizations that implement technical controls without governance around them.

Category	ID	Focus
Organizational Context	GV.OC	The mission, stakeholder expectations, dependencies, and legal or regulatory requirements that shape risk decisions.
Risk Management Strategy	GV.RM	Priorities, constraints, and risk tolerance and appetite statements used to support operational risk decisions.
Roles, Responsibilities, and Authorities	GV.RR	Cybersecurity roles and authorities established and communicated to foster accountability.
Policy	GV.PO	Organizational cybersecurity policy established, communicated, and enforced.
Oversight	GV.OV	Results of risk management activities used to inform, improve, and adjust the strategy.
Cybersecurity Supply Chain Risk Management	GV.SC	Processes to identify, manage, and monitor cyber risk from suppliers and third parties.

05. The Identify Function (ID)

Identify builds the foundation for every other Function: you cannot protect, detect, respond to, or recover from what you have not first understood.

Category	ID	Focus
Asset Management	ID.AM	Data, personnel, devices, systems, and facilities are inventoried and managed consistent with their relative importance.
Risk Assessment	ID.RA	The organization understands the cybersecurity risk to its operations, assets, and individuals.
Improvement	ID.IM	Improvements to cybersecurity risk management processes are identified across all Functions.

06. The Protect Function (PR)

Protect covers the safeguards used to manage risk and limit or contain the impact of a cybersecurity event.

Category	ID	Focus
Identity Management, Authentication, and Access Control	PR.AA	Access to physical and logical assets is limited to authorized users, services, and hardware.
Awareness and Training	PR.AT	Personnel are provided cybersecurity awareness and training so they can perform their roles securely.
Data Security	PR.DS	Data is managed consistent with the organization's risk strategy to protect its confidentiality, integrity, and availability.
Platform Security	PR.PS	The hardware, software, and services of physical and virtual platforms are managed consistent with the risk strategy.
Technology Infrastructure Resilience	PR.IR	Security architectures are managed to protect asset confidentiality, integrity, availability, and organizational resilience.

07. The Detect Function (DE)

Detect enables the timely discovery and analysis of anomalies, indicators of compromise, and other potentially adverse events.

Category	ID	Focus
Continuous Monitoring	DE.CM	Assets are monitored to find anomalies, indicators of compromise, and other potentially adverse events.
Adverse Event Analysis	DE.AE	Anomalies and indicators of compromise are analyzed to characterize events and detect cybersecurity incidents.

08. The Respond Function (RS)

Respond covers the actions taken once a cybersecurity incident has been detected, to contain and manage its impact.

Category	ID	Focus
Incident Management	RS.MA	Responses to detected cybersecurity incidents are managed, including planning and execution.
Incident Analysis	RS.AN	Investigations are conducted to ensure an effective response and support forensics and recovery.
Incident Response Reporting and Communication	RS.CO	Response activities are coordinated with internal and external stakeholders as required by law, regulation, or policy.
Incident Mitigation	RS.MI	Activities are performed to prevent expansion of an event and mitigate its effects.

09. The Recover Function (RC)

Recover covers restoring assets and operations affected by a cybersecurity incident, and capturing lessons learned to reduce the impact of future events.

Category	ID	Focus
Incident Recovery Plan Execution	RC.RP	Restoration activities are performed to ensure operational availability of systems and services affected by an incident.
Incident Recovery Communication	RC.CO	Restoration activities are coordinated with internal and external parties.

10. CSF Tiers — Organizational Risk Management Maturity

Tiers describe the rigor of an organization's cybersecurity risk governance and management practices — they are not a maturity score to “pass,” and a higher Tier is not appropriate for every organization. Tiers help characterize current practice and support a conversation about whether that practice is sufficient for the organization's risk.

Tier	Characteristics
Tier 1 — Partial	Risk management practices are informal and reactive; limited awareness of organizational cybersecurity risk at the enterprise level.
Tier 2 — Risk Informed	Risk management practices are approved by management but may not be established as organization-wide policy.
Tier 3 — Repeatable	Risk management practices are formally approved, expressed as policy, and regularly updated based on changes in requirements and threat landscape.
Tier 4 — Adaptive	The organization adapts its cybersecurity practices in near real time based on lessons learned and predictive indicators, using continuous improvement across the enterprise.

11. CSF Profiles — Current State, Target State, Gaps

A Profile is a snapshot of how an organization is achieving — or intends to achieve — the outcomes described in the CSF Core, selected and prioritized for that organization's specific mission, risk tolerance, and resources.

Dimension	Current Profile	Target Profile
What it describes	The Categories and Subcategories the organization is currently achieving, and how well.	The Categories and Subcategories the organization wants to achieve to manage its cybersecurity risk appropriately.
Purpose	Establishes a baseline for comparison.	Establishes the goal state that guides prioritization and investment.
The gap between them	—	The difference between Current and Target Profiles becomes the prioritized action plan.

NIST also publishes **Community Profiles** — sector- or topic-specific Target Profiles developed collaboratively (for example, for small business or a specific industry) that organizations can adopt or adapt rather than building a Target Profile entirely from scratch.

12. Applying CSF 2.0 — A Practical Implementation Path

1. **Step 1 — Scope the Profile.** Decide which part of the organization, business line, or system the Profile will cover.
2. **Step 2 — Gather information.** Collect existing risk assessments, policies, control documentation, and prior audit findings relevant to the scope.
3. **Step 3 — Create the Current Profile.** Assess, Subcategory by Subcategory, how the organization currently performs against the Core.
4. **Step 4 — Create the Target Profile.** Define the outcomes the organization needs to achieve, informed by risk tolerance, regulatory obligations, and any relevant Community Profile.
5. **Step 5 — Analyze gaps.** Compare Current and Target Profiles to identify and prioritize gaps by risk and business impact.
6. **Step 6 — Develop and implement an action plan.** Assign owners, resource the highest-priority gaps, and track remediation.
7. **Step 7 — Repeat.** Update the Current Profile as controls mature and revisit the Target Profile as the business and threat landscape change — CSF adoption is continuous, not a one-time project.

13. Worked Example — Building a Simple Organizational Profile

Consider a small SaaS company building its first CSF Profile. Rather than assessing all 22 Categories at once, it starts with a handful of Subcategories most relevant to its risk — illustrated below.

Subcategory	Current State	Target State	Gap / Action
GV.RM — Risk Management Strategy	Risk tolerance discussed informally by leadership; not documented.	A written risk appetite statement approved by leadership and reviewed annually.	Draft and approve a formal risk appetite statement.
ID.AM — Asset Management	Cloud assets tracked manually in a spreadsheet, updated irregularly.	An automated, continuously updated asset inventory covering cloud and SaaS assets.	Deploy a cloud asset discovery tool and retire the manual spreadsheet.
PR.AA — Access Control	MFA enforced for admin accounts only.	MFA enforced for all users, with risk-based step-up authentication for privileged access.	Extend MFA enforcement organization-wide; evaluate conditional access policies.
DE.CM — Continuous Monitoring	Basic cloud provider alerts reviewed ad hoc.	Centralized logging with defined alert thresholds and a documented on-call review process.	Implement a SIEM or managed detection service; define alert-review SLAs.

14. CSF 2.0 Quick Reference

All six Functions and 22 Categories, in one place, for quick lookup during assessments and planning.

Function	Category	ID
Govern	Organizational Context	GV.OC
Govern	Risk Management Strategy	GV.RM
Govern	Roles, Responsibilities, and Authorities	GV.RR
Govern	Policy	GV.PO
Govern	Oversight	GV.OV
Govern	Cybersecurity Supply Chain Risk Management	GV.SC
Identify	Asset Management	ID.AM
Identify	Risk Assessment	ID.RA
Identify	Improvement	ID.IM
Protect	Identity Management, Authentication, and Access Control	PR.AA
Protect	Awareness and Training	PR.AT
Protect	Data Security	PR.DS
Protect	Platform Security	PR.PS
Protect	Technology Infrastructure Resilience	PR.IR
Detect	Continuous Monitoring	DE.CM
Detect	Adverse Event Analysis	DE.AE
Respond	Incident Management	RS.MA
Respond	Incident Analysis	RS.AN
Respond	Incident Response Reporting and Communication	RS.CO
Respond	Incident Mitigation	RS.MI
Recover	Incident Recovery Plan Execution	RC.RP
Recover	Incident Recovery Communication	RC.CO

NIST publishes informative references mapping many CSF Subcategories to ISO/IEC 27001, SOC 2 Trust Services Criteria, and NIST SP 800-53 — a single CSF-based assessment can support several compliance programs at once rather than duplicating effort across frameworks.

15. Common Implementation Gaps

Common Gap	Why It Slows Adoption
Treating CSF as a checklist to complete once	CSF is designed for continuous reassessment; a Profile built once and never revisited quickly becomes stale.
Assessing all 22 Categories before taking any action	Comprehensive assessment can take months, delaying remediation of the highest-risk gaps that are already visible.
Skipping the Govern function	Organizations that jump straight to technical Protect and Detect controls often lack the strategy and accountability to sustain them.
No documented risk tolerance	Without a stated risk appetite, gap prioritization defaults to whichever risk was discussed most recently, not the organization's actual priorities.
Building a Target Profile in isolation from the business	A Target Profile set by security alone, without business input, is difficult to fund and often abandoned.
No owner assigned to the action plan	Identified gaps without a named owner and timeline rarely get remediated.

16. TSEC NIST CSF 2.0 Approach

TSEC Risk & Cyber Advisory LLC helps organizations turn CSF 2.0 from a reference document into an operating program — scoping and building Current and Target Profiles, prioritizing gaps by actual business risk, and mapping the result to any other frameworks the organization must also satisfy.

Service Component	Description
Profile Development	Build a Current Profile and a risk-informed Target Profile across all six Functions.
Gap Analysis	Identify and prioritize gaps between Current and Target Profiles by business impact.
Multi-Framework Mapping	Map the resulting CSF Profile to ISO/IEC 27001, SOC 2, and NIST SP 800-53 to avoid duplicated compliance work.
Action Plan & Remediation Support	Assign owners, timelines, and hands-on support closing prioritized gaps.
Ongoing Advisory	Recurring Profile updates as controls, threats, and business context evolve.

17. From Framework to Implementation

This guide covers the structure and vocabulary of CSF 2.0. Turning it into a working program — a real Current Profile, a defensible Target Profile, and a prioritized, funded action plan — is the next step.

Explore the TSEC NIST CSF Professional Pack™

A complete CSF 2.0 toolkit: Current and Target Profile templates, a Subcategory-level assessment workbook, gap-analysis scoring, and a multi-framework crosswalk built on the model in this guide.

Info@tsecgrc.com | www.tsecgrc.com

Revision History

Version	Date	Author	Summary of Changes
1.0	September 2026	TSEC Risk & Cyber Advisory LLC	Initial publication of the NIST CSF 2.0 Executive & Practitioner Guide.